Microsoft 365 Mail Hygiene & Anti-Spam — EOP / Defender for Office 365

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary 4

Solution Overview 4

What this is . . . 4

How it works — the hygiene stack . . . 5

Reference design (the model this solution deploys) . . . 6

Benefits . . . 6

Limitations / scope boundaries . . . 6

Deployment model . . . 7

Requirements 7

1. Confirmed EOP and (if applicable) Defender for Office 365 licensing . . . 7

2. Email authentication (SPF, DKIM, DMARC) on all sending domains . . . 8

3. Defined pilot scope (group, users, or domain) for policy targeting . . . 8

4. A test mailbox and a way to send controlled test messages . . . 8

5. Quarantine review owner and notification decision . . . 9

6. Baseline of current hygiene configuration and mail-flow rules (transport rules) . . . 9

7. Government cloud confirmation (if applicable) . . . 9

Global Requirements — Microsoft 365 / Exchange Messaging Solutions 10

1. Microsoft 365 tenant with Exchange Online . . . 10

2. Administrative access (least-privilege Exchange/365 roles) . . . 11

3. Exchange Online PowerShell (EXO V3) + Graph toolchain . . . 11

4. DNS control for the mail domains . . . 11

5. Hybrid Exchange & Active Directory (for hybrid solutions) . . . 11

6. A pilot scope and change control . . . 12

Implementation 12

Stage 1 — Assess (read-only) . . . 13

Stage 2 — Design . . . 13

Stage 3 — Configure (against the pilot scope) . . . 13

Stage 4 — Pilot . . . 16

Stage 5 — Validate . . . 16

Stage 6 — Expand . . . 16

Rollback (any stage) . . . 17

Testing & Validation 17

T1 — Anti-spam verdict (GTUBE) . . . 17

T2 — Anti-malware (EICAR) . . . 17

T3 — Spoof / anti-phishing (unauthenticated spoof of your domain) . . . 17

T4 — Bulk mail threshold (BCL) . . . 18
T5 — Safe Attachments (Defender for Office 365 only) . . . 18
T6 — Safe Links (Defender for Office 365 only) . . . 18
T7 — Quarantine notification & release . . . 18
T8 — Tenant Allow/Block List behaves . . . 19
T9 — No legitimate mail lost (false-positive gate) . . . 19
Troubleshooting 19
T-A. Spam/malware/phish delivered to the Inbox despite the policy . . . 19
T-B. Legitimate mail is being quarantined (false positive) . . . 20
T-C. "Safe Links / Safe Attachments / impersonation protection is missing" . . . 20
T-D. Cannot reach the portal / cmdlet errors on a Government tenant . . . 20
T-E. Quarantine notifications not delivered / users can't request release . . . 20
T-F. A user gets a different verdict than expected . . . 21
T-G. EOP not filtering correctly when a third-party gateway is in front . . . 21
T-H. Spoof of your own domain still delivered . . . 21
T-I. `Connect-ExchangeOnline` or a cmdlet fails . . . 21
T-J. Changes seem to have no effect immediately . . . 21
Best Practices 22
Baseline & policy management . . . 22
Licensing discipline . . . 22
Authentication foundation . . . 22
Quarantine & allow/block governance . . . 22
Tuning to minimize false positives . . . 23
Third-party gateways . . . 23
Change control & operations . . . 23
Deliverables Summary 23
Documentation . . . 23
PowerShell tools (5) — EXO V3 / Microsoft Graph, read-only or `-WhatIf` by default . . . 24
Appendix A — PowerShell Scripts 26

Executive Summary

Outcome. Microsoft 365 mail hygiene is configured and tuned so that phishing, spoofing, malware, and malicious links/attachments are **blocked**, while legitimate business mail **flows without being wrongly quarantined**. Default, out-of-the-box filtering lets threats through *and* traps good mail — both erode trust. This solution fixes both.

Approach. It configures the two layers of the Microsoft cloud email-security stack: **Exchange Online Protection (EOP)** — anti-spam, anti-malware, connection filtering, and anti-spoofing (available to every Exchange Online tenant) — and, where licensed, **Microsoft Defender for Office 365** — anti-phishing (impersonation protection), **Safe Links**, and **Safe Attachments**. It applies Microsoft's recommended **preset security policies** (Standard, with Strict for high-risk roles) rather than hand-built policies where possible, governs **quarantine** with notifications and right-sized release permissions, and manages every exception through the supported **Tenant Allow/Block List** — retiring the legacy `SCL -1` transport rules that silently defeat filtering.

Why it is low-risk. Mail-hygiene changes are high-impact to production mail, so the work follows a disciplined **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** model: a read-only assessment captures the rollback baseline, all changes are staged on a **pilot scope** first, explicit **pass/fail gates** (threats blocked, false-positive rate low, quarantine reviewed) must be met before expansion, and a **documented rollback** exists at every step. Five PowerShell tools (Exchange Online PowerShell V3 / Microsoft Graph) assess, help configure, validate, and report — all **read-only or dry-run (`-WhatIf`) by default**, with no stored credentials.

One critical caveat, surfaced up front. Advanced protections — anti-phishing impersonation, Safe Links, and Safe Attachments — **require Defender for Office 365 (Plan 1 or 2)** and do not exist on an EOP-only tenant. **Verify the tenant's plan and cloud (Commercial vs Government) before starting.** The solution delivers substantial value on EOP alone and flags every plan-dependent step.

The result: hygiene that stops threats and passes good mail — tuned to a proven baseline, quarantine governed, false positives down — self-guided and validated at a fraction of consulting cost.

Solution Overview

What this is

This solution configures and tunes **Microsoft 365 mail hygiene** so that malicious and unwanted mail is blocked while legitimate mail flows without being wrongly quarantined. It covers the two layers of the Microsoft cloud email-security stack:

- **Exchange Online Protection (EOP)** — included with every Exchange Online mailbox. Provides

anti-malware, **anti-spam** (including bulk and high-confidence spam handling), **connection filtering** (IP Allow/Block lists), and **anti-spoofing / spoof intelligence**, plus **outbound spam** controls.

- **Microsoft Defender for Office 365** — a **licensed add-on** (Plan 1 or Plan 2, or bundled in

Microsoft 365 E5 / E5 Security). Adds **anti-phishing** (impersonation and mailbox-intelligence protection), **Safe Links** (time-of-click URL protection), and **Safe Attachments** (detonation of attachments in a sandbox). Plan 2 additionally provides Threat Explorer, Automated Investigation & Response (AIR), and

Attack Simulation Training.

> ***PLAN / LICENSING IS DECISIVE — VERIFY BEFORE YOU START.*** *Which controls you can configure depends entirely on licensing. EOP anti-spam/anti-malware/anti-spoof is available to all Exchange Online tenants.* ***Anti-phishing impersonation protection, Safe Links, and Safe Attachments require Defender for Office 365 (Plan 1 or Plan 2).*** *Do* ***not*** *assume a control exists — confirm your plan in the Microsoft 365 admin center under* ***Billing > Licenses*** *and verify capability in your own tenant before designing around it. Where this document describes a Defender for Office 365 feature, it is flagged as such.*

The solution delivers the reference design, the exact ordered implementation (portal paths **and** Exchange Online PowerShell cmdlets), validation procedures with pass/fail gates, troubleshooting, durable best practices, and **five PowerShell tools** (EXO V3 / Microsoft Graph) that assess, help configure, validate, and report on the hygiene posture — all read-only or `-WhatIf` by default.

How it works — the hygiene stack

Inbound mail is evaluated in layers before it reaches the mailbox:

1. **Connection filtering (EOP)** — the IP Allow / IP Block lists and the safe-list. Evaluated

first, at the connection.

1. **Anti-malware (EOP)** — malware filtering and the common-attachments filter; malware is

quarantined.

1. **Anti-spam / anti-spoof (EOP)** — content filtering assigns a **spam confidence level (SCL)**

and **bulk complaint level (BCL)**; spoof intelligence evaluates unauthenticated senders spoofing your domains or others. Verdicts: spam, high-confidence spam, phishing, high-confidence phishing, bulk. Each verdict has an **action** (move to Junk, quarantine, etc.).

1. **Anti-phishing (Defender for Office 365)** — impersonation protection (user and domain),

mailbox intelligence, and spoof intelligence tuning.

1. **Safe Attachments (Defender for Office 365)** — attachments are detonated in a sandbox

(Dynamic Delivery / Block / Replace).

1. **Safe Links (Defender for Office 365)** — URLs are wrapped and checked at time of click.

Quarantine holds messages that policies quarantine; a **quarantine policy** controls what recipients can do (view, request release, release, block sender) and whether they receive **quarantine notifications**. The **Tenant Allow/Block List (TABL)** is the supported way to allow or block specific senders, domains, URLs, and file hashes tenant-wide.

Preset security policies vs custom

Microsoft ships two **preset security policies** with recommended, Microsoft-maintained settings:

- **Standard protection** — recommended baseline for most organizations.
- **Strict protection** — more aggressive; more mail quarantined, higher protection.

Presets cover EOP (anti-spam/malware/spoof) and, where licensed, Defender for Office 365 (anti-phish/Safe Links/Safe Attachments) together, applied to the users/groups/domains you scope. The

alternative is **custom policies**, which you tune manually. This solution defaults to a **preset-first** approach (fewer moving parts, Microsoft keeps them current) and uses **custom policies only where a specific requirement is not met by a preset** — for example a mail-flow rule exception or a tuned bulk threshold.

Reference design (the model this solution deploys)

- **Baseline:** Apply the **Standard** preset security policy to a **pilot scope** first, then expand. Escalate specific groups (executives, finance, high-risk roles) to **Strict** where the organization accepts more aggressive quarantining.
- **Quarantine policy:** Use the built-in `DefaultFullAccessWithNotificationPolicy` (recipients get notifications and can request release) as the default; reserve admin-only release for high-confidence phishing/malware.
- **Allow/Block:** Manage exceptions **only** through the **Tenant Allow/Block List** — never by disabling filters or using broad mail-flow-rule bypasses.
- **Authentication foundation:** SPF, DKIM, and DMARC on all sending domains so spoof intelligence and anti-phishing have authenticated signals to reason about (email authentication is a prerequisite — see Requirements).
- **Naming convention:** every custom artifact is named `<Purpose> – <Scope> – <Stage>`, e.g. `Anti-Spam – Inbound – Pilot`, `Anti-Phish – Exec – Prod`, `Quarantine – Notify – Prod`.

Benefits

- **Fewer threats delivered** — phishing, spoofing, malware, and malicious links/attachments are blocked at Microsoft-recommended (or stricter) levels.
- **Fewer false positives** — quarantine is governed, allow/block is deliberate, and bulk/spam thresholds are tuned to the organization, so legitimate mail is not lost.
- **Maintainable** — preset policies stay current automatically; custom drift is minimized.
- **Auditable** — allow/block entries, quarantine actions, and policy scope are all reviewable and reportable (the provided scripts produce these reports).
- **Low-risk rollout** — pilot-first with explicit gates and a documented rollback.

Limitations / scope boundaries

- **Defender for Office 365 features require the license.** Without Plan 1/2 you get EOP only; this is flagged throughout. **Verify your plan.**
- **Not a replacement for email authentication.** SPF/DKIM/DMARC setup is a prerequisite, not the subject of this solution (it is the foundation hygiene relies on).

• **Third-party gateways** (a hygiene gateway or connector-based third-party filter in front of EOP)

are integrated at the pattern level only — their consoles are deferred to the vendor's docs, and **Enhanced Filtering for Connectors (skip listing)** is noted where a third-party sits in front.

• **Commercial vs Government cloud:** portal URLs and some endpoint availability differ on

GCC / GCC High / DoD (e.g. `security.microsoft.com` vs `security.microsoft.us`, and certain Defender for Office 365 features roll out later or differently). Where setup materially differs, it is flagged — **do not assume Commercial paths are universal**.

• This solution tunes **hygiene**; it does not cover mailbox migration, connectors for hybrid mail

routing, or archiving (separate solutions).

Deployment model

The house model is **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**, pilot-first, with explicit pass/fail gates and a documented rollback at each stage. Mail hygiene changes are **high-impact to production mail** (a mis-tuned policy can quarantine legitimate business mail), so every change is staged on a pilot scope, validated against the gates in the Testing section, and only then expanded — with the rollback ready.

Requirements

These are the **solution-specific** prerequisites for configuring and tuning Microsoft 365 mail hygiene. They build on — and do not repeat — the shared **Global Requirements for Messaging Solutions** (`global-requirements-messaging.md`): a Microsoft 365 tenant with Exchange Online, least-privilege admin roles, the EXO V3 + Graph toolchain, DNS control, hybrid/AD access where applicable, and a pilot scope with change control. Verify those first, then confirm the additions below.

Each requirement below lists **Description / Why required / How to verify / How to implement if missing**.

1. Confirmed EOP and (if applicable) Defender for Office 365 licensing

• **Description:** A definitive answer to **which hygiene plan the tenant has** — EOP only, or

Defender for Office 365 **Plan 1** or **Plan 2** (standalone, or bundled in Microsoft 365 E5 / E5 Security / Business Premium, which includes Defender for Office 365 Plan 1).

• **Why required:** This is the single most consequential prerequisite. **Anti-phishing

impersonation protection, Safe Links, and Safe Attachments are Defender for Office 365 features and do not exist on an EOP-only tenant.** Designing around a feature you are not licensed for wastes effort and produces a non-working plan. Plan 1 vs Plan 2 also differs (Plan 2 adds Threat Explorer, AIR, Attack Simulation).

• **How to verify:** Microsoft 365 admin center > **Billing > Licenses**; look for *Microsoft

Defender for Office 365 (Plan 1/Plan 2)* or a bundle that includes it. In the Microsoft Defender portal (`security.microsoft.com`, or `security.microsoft.us` for Government), the presence of **Safe**

Links and **Safe Attachments** policy pages under **Email & collaboration > Policies & rules > Threat policies** indicates Defender for Office 365 is licensed. **Verify capability in your own tenant — do not assume from the SKU name.**

• **How to implement if missing:** If only EOP is present, either proceed with EOP-only hygiene (still substantial) or license Defender for Office 365 for the users who need advanced protection before configuring those features. Defender for Office 365 can be licensed per-user.

2. Email authentication (SPF, DKIM, DMARC) on all sending domains

• **Description:** Valid **SPF** (TXT), **DKIM** (signing enabled in Exchange Online / CNAMEs published), and **DMARC** (TXT) records for every domain the organization sends mail from.

• **Why required:** Spoof intelligence, anti-phishing, and DMARC-based handling all depend on authenticated signals. Without DKIM and DMARC, legitimate mail is harder to distinguish from spoofing, increasing both false positives and missed threats.

• **How to verify:** Check DNS for SPF/DMARC TXT records; in the Defender portal check that spoof intelligence has data. Confirm DKIM in Exchange Online PowerShell: `Get-DkimSigningConfig` (each domain should show `Enabled = True`). The provided validation script summarizes authentication posture.

• **How to implement if missing:** Publish/repair SPF, enable and publish DKIM (`Set-DkimSigningConfig -Identity <domain> -Enabled $true` after the CNAMEs exist), and publish a DMARC record (start at `p=none` for monitoring, then tighten). This is a foundation, not part of hygiene tuning itself — but hygiene will underperform without it.

3. Defined pilot scope (group, users, or domain) for policy targeting

• **Description:** A named **pilot group** (a mail-enabled security group or a set of users/domain) to which the baseline is applied first — distinct from fleet-wide.

• **Why required:** Preset and custom policies are **scoped by users/groups/domains**. A pilot scope lets you validate the baseline and tuning against real mail before expanding, per the deployment model. It also enables clean rollback (remove the scope).

• **How to verify:** Confirm the pilot group exists and contains representative mailboxes (including a high-volume user and an exec/finance user if relevant). `Get-DistributionGroup` / `Get-UnifiedGroup` or the Microsoft 365 admin center.

• **How to implement if missing:** Create a mail-enabled security group (e.g. `Hygiene-Pilot`) and add representative members.

4. A test mailbox and a way to send controlled test messages

• **Description:** At least one **test mailbox** in the pilot scope and a method to send **safe test

messages **— e.g. the** GTUBE **spam-test string, the** EICAR** anti-malware test file, and a known-benign bulk sender — plus a way to send from an external address you control.

• **Why required:** Validation (Testing section) requires provoking each verdict — spam, malware, spoof, safe-link/attachment — and confirming the expected action without using real malware.

• **How to verify:** Confirm you have an external mailbox (or a controlled external sender) and the standard test artifacts (GTUBE, EICAR) available.

• **How to implement if missing:** Prepare a controlled external sender and the standard test strings/files before validation. **Never use real malware; use EICAR/GTUBE only.**

5. Quarantine review owner and notification decision

• **Description:** A named **owner** for quarantine review and a decision on **quarantine notification** cadence and recipient permissions (view / request release / release / block).

• **Why required:** Quarantine is only effective if someone reviews it and end-users know how to request release of false positives. The quarantine policy encodes these permissions.

• **How to verify:** Confirm an owner (e.g. the messaging team) and the intended recipient permission level.

• **How to implement if missing:** Assign the owner and agree the notification/permission model before enabling quarantine-heavy actions.

6. Baseline of current hygiene configuration and mail-flow rules (transport rules)

• **Description:** A captured **before** state: existing anti-spam/anti-malware/anti-phish policies, the Tenant Allow/Block List, connection filter, quarantine policies, and any **mail-flow rules (transport rules)** that bypass or alter filtering (e.g. SCL-override rules, allow-list rules).

• **Why required:** Legacy mail-flow rules that set `SCL -1` (bypass spam filtering) or broadly allow senders are the most common cause of both missed threats **and** confusing behavior after tuning. You must know what exists before you change anything, and to roll back.

• **How to verify:** Run the provided discovery script (read-only). It exports current policies, TABL entries, connection filter, quarantine policies, and transport rules that affect filtering.

• **How to implement if missing:** Run the discovery script and archive its output as the rollback baseline before any change.

7. Government cloud confirmation (if applicable)

• **Description:** Confirmation of whether the tenant is **Commercial** or a **Government cloud** (GCC / GCC High / DoD).

• **Why required:** Portal URLs and some feature availability differ. The Defender portal is `security.microsoft.com` (Commercial) vs `security.microsoft.us` (GCC High/DoD); certain Defender for Office 365 capabilities roll out later or differently on sovereign clouds. Using the wrong URL or assuming a feature exists will block the work.

• **How to verify:** Confirm the tenant's cloud instance with the tenant owner / in the admin center. **Verify feature availability in your own tenant.**

• **How to implement if missing:** Record the cloud instance and substitute the correct portal URLs throughout; flag any feature that is not yet available on that cloud.

Global Requirements — Microsoft 365 / Exchange Messaging Solutions

These requirements apply to **every** solution in the **Messaging** category (Exchange Online & Exchange hybrid mail flow, connectors, mail hygiene, email authentication, federation, archiving, client connectivity, and messaging support operations). They are the common foundation each solution assumes is already in place (or stands up as part of its own Requirements section). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Messaging solution).*** *The **Exchange admin center (EAC)**, the **Microsoft 365 admin center**, **Exchange Online PowerShell (EXO V3 module)**, **Microsoft Graph**, and on-premises **Exchange Server / Active Directory** are authored at exact, current click-by-click and cmdlet detail from Microsoft's public documentation. Where a capability, default, or portal path is **version- or plan-dependent** (Exchange Server build/CU, EOP vs Defender for Office 365 plan, Exchange Online Archiving / auto-expanding archive availability, Commercial vs Government cloud), it is **cited or flagged "verify in your tenant/version"** — never invented. **Third-party mail hygiene, archiving, and signature/gateway products** are integrated at the pattern level; their internal consoles are deferred to the vendor's own docs. **Commercial vs Government (GCC/GCC High/DoD)** portal URLs and endpoints differ — where a solution's setup materially differs on a sovereign cloud, flag it (per the house Commercial-vs-Government rule). Automation is delivered as **PowerShell** (Exchange Online PowerShell / Graph) — never with hardcoded credentials or secrets in code.*

1. Microsoft 365 tenant with Exchange Online

• **Description:** A Microsoft 365 tenant with **Exchange Online** and the appropriate licensing for the capability in scope (e.g. Exchange Online Plan 1/2, EOP, **Defender for Office 365** for advanced hygiene, Exchange Online Archiving / auto-expanding archive where required).

• **Why required:** All mail-flow, hygiene, archiving, and client configuration is performed against this tenant and depends on the right plan.

• **How to verify:** Sign in to the Microsoft 365 admin center; confirm the Exchange Online subscription and license counts under **Billing > Licenses**.

• **How to implement if missing:** Provision/assign the required licensing before starting.

2. Administrative access (least-privilege Exchange/365 roles)

• **Description:** Administrative access with the **least-privilege role** the solution names —

typically **Exchange Administrator** (or specific EAC role groups such as Organization Management, Recipient/Records/Hygiene Management), and **Global Administrator** only where genuinely required (e.g. federation/ADFS, connector auth).

• **Why required:** Mail-flow, connector, hygiene, archiving, and federation changes require the

corresponding admin role.

• **How to verify:** Confirm the role assignment in the Microsoft 365 admin center / Entra roles.

• **How to implement if missing:** Have a Global Admin assign the least-privilege role under change control.

3. Exchange Online PowerShell (EXO V3) + Graph toolchain

• **Description:** A workstation with the **ExchangeOnlineManagement (EXO V3)** PowerShell module and,

where used, **Microsoft Graph PowerShell**; modern-auth / MFA-capable admin sign-in.

• **Why required:** Configuration, automation, and the provided scripts run through EXO PowerShell /

Graph; Basic Auth is retired.

• **How to verify:** `Connect-ExchangeOnline` succeeds with the admin account; `Get-Module

ExchangeOnlineManagement`.

• **How to implement if missing:** Install the module (`Install-Module ExchangeOnlineManagement`) and

confirm modern-auth sign-in before running the steps.

4. DNS control for the mail domains

• **Description:** Ability to create/modify **DNS records** (MX, SPF (TXT), DKIM (CNAME), DMARC (TXT),

Autodiscover, and connector/host records) for the domains in scope.

• **Why required:** Email authentication, mail routing/coexistence, connector validation, and client

autodiscover all depend on DNS.

• **How to verify:** Confirm access to the authoritative DNS zone for each mail domain.

• **How to implement if missing:** Coordinate with whoever controls DNS; stage changes under change

control (mail-flow and authentication changes are high-impact).

5. Hybrid Exchange & Active Directory (for hybrid solutions)

• **Description:** For **hybrid / on-premises** solutions, access to the on-premises **Exchange Server**

organization (correct roles/CU), **Active Directory**, **Azure AD Connect** (directory sync), and the relevant network/firewall paths (e.g. for Edge/transport, hybrid connectors, autodiscover).

- **Why required:** Hybrid mail flow, Edge Transport, connectors, and federation read from and change

the on-premises side.

- **How to verify:** Confirm on-prem Exchange admin access, AD access, and that directory sync is healthy.
- **How to implement if missing:** Obtain access and confirm the on-prem Exchange/AD/AAD-Connect health

before making hybrid changes.

6. A pilot scope and change control

- **Description:** A **pilot group / accepted-domain / test mail flow** to validate on before fleet-wide

rollout, and a **change-control** process for production changes (mail flow, connectors, DNS, authentication, hygiene policy are all high-impact).

- **Why required:** Every solution follows an **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**

model; the pilot proves the design and change control protects production mail flow.

- **How to verify:** Confirm a named pilot scope and an approval/change window are available.
- **How to implement if missing:** Define a pilot scope and agree change control with the messaging/

service owners before making production changes.

*The deployment model across every Messaging solution is the same: **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**, with explicit pass/fail gates and a documented rollback for production changes. Automation is delivered as **PowerShell** (Exchange Online PowerShell / Graph) — never with hardcoded credentials or secrets in code.*

Implementation

This is the exact, ordered implementation, following the house model **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**, pilot-first, with pass/fail gates and a documented rollback. Every artifact is named `<Purpose> – <Scope> – <Stage>` and reused by that exact name in Testing, Troubleshooting, and the scripts.

> ***Portal note:*** *Steps use the **Microsoft Defender portal** at* `security.microsoft.com` *(Commercial). On **GCC High / DoD** use* `security.microsoft.us`*; on **GCC** confirm the correct URL for your tenant. Exchange admin center is* `admin.exchange.microsoft.com` *(*`admin.exchange.microsoft.us` *for GCC High/DoD).* ***Verify URLs and feature availability in your tenant. Connect first (PowerShell):*** `Connect-ExchangeOnline` *(add* `-ExchangeEnvironmentName O365USGovGCCHigh` *or* `O365USGovDoD` *for those clouds). Use a least-privilege admin (Security Administrator + Exchange Administrator covers hygiene). No stored credentials.*

Stage 1 — Assess (read-only)

Goal: capture the current state as the rollback baseline and identify risks.

1. Run the discovery script `Get-MailHygieneAssessment.ps1` (read-only). It exports, for the tenant: anti-spam (hosted content filter) policies + rules, anti-malware policies, anti-phish policies, Safe Links / Safe Attachments policies (if Defender for Office 365 is licensed), connection filter policy, quarantine policies, Tenant Allow/Block List entries, preset policy state, and — critically — **mail-flow rules (transport rules) that alter filtering** (SCL overrides, allow-list rules, `SetHeaderName`/`SetSCL` actions). Archive the output as the **rollback baseline**.

1. Note **licensing** (from Requirements #1): EOP-only vs Defender for Office 365 Plan 1/2. This determines which of Stages 3d–3f you perform.

1. Review the assessment against the **Standard preset** recommendations (the script flags gaps and risky legacy rules, e.g. any rule setting `SCL -1`).

Gate 1 (pass/fail): You have a complete before-state export **and** a documented list of any legacy filter-bypassing transport rules. **Fail** → do not proceed until the baseline is captured.

Stage 2 — Design

Goal: decide the target configuration before touching production.

1. **Choose the baseline:** default to the **Standard** preset for the pilot scope. Decide whether any group (execs, finance) will be escalated to **Strict** at Expand.

1. **Quarantine model:** choose the quarantine policy per verdict. Recommended default: `DefaultFullAccessWithNotificationPolicy` (recipients notified, can request release) for spam/bulk; **admin-only** (`AdminOnlyAccessPolicy`) for high-confidence phishing and malware.

1. **Allow/Block model:** all exceptions go through the **Tenant Allow/Block List** — decide the initial known-good senders/domains and any known-bad to block. **No new SCL-override transport rules.**

1. **Name the artifacts** (create these exact names in Stage 3):

• Preset scope target: pilot group `Hygiene-Pilot`.

• Custom (only if a preset gap requires it): `Anti-Spam – Inbound – Pilot`, `Anti-Malware – Inbound – Pilot`, `Anti-Phish – Standard – Pilot`, `Safe-Links – Standard – Pilot`, `Safe-Attach – Standard – Pilot`, `Quarantine – Notify – Prod`.

1. **Rollback plan:** for presets, rollback = remove the pilot scope from the preset (protection reverts to prior state). For custom policies, rollback = disable/delete the named policy. For transport-rule cleanup, rollback = re-import the archived rule from the baseline.

Gate 2: Design (baseline, quarantine model, allow/block list, artifact names, rollback) documented and approved under change control.

Stage 3 — Configure (against the pilot scope)

*Do everything here **scoped to** `Hygiene-Pilot`, not the whole tenant.*

3a. Clean up filter-bypassing transport rules (if found in Stage 1)

Legacy rules that set `SCL -1` or broadly allow senders undermine hygiene. In EAC > **Mail flow > Rules**, or PowerShell:

- Review each flagged rule (`Get-TransportRule | Where-Object {$_.SetSCL -eq '-1'}`).
- Replace broad allow-list rules with **Tenant Allow/Block List** entries (Stage 3g).
- Disable (don't delete yet) rules you intend to retire: `Disable-TransportRule -Identity "<name>"`.

Keep the export so you can `Import`/re-enable to roll back.

3b. Connection filtering (EOP) — `Connection-Filter – Default`

The connection filter policy is the **default** policy (single, tenant-wide; not scoped). Configure only deliberate IP allow/block; **avoid** `EnableSafeList` **unless required**:

- Defender portal > **Email & collaboration > Policies & rules > Threat policies > Anti-spam** >

Connection filter policy (Default). Add only trusted infrastructure IPs to **Allow**, known-bad to **Block**.

- PowerShell: `Set-HostedConnectionFilterPolicy -Identity Default -IPAllowList @('x.x.x.x') -IPBlockList @('y.y.y.y')`.
- **If a third-party gateway sits in front of EOP:** do **not** add its IPs here; instead configure

Enhanced Filtering for Connectors (skip listing) on the inbound connector so EOP sees the true source IP. Defer the third-party console to its vendor docs.

3c. Apply the Standard preset (EOP + Defender for Office 365) — pilot scope

Preferred baseline. In the Defender portal > **Threat policies > Preset security policies**:

1. Edit **Standard protection** > turn it **On**.
2. Under **EOP protections apply to**, add the `Hygiene-Pilot` group. Under **Defender for Office 365 protections apply to** (only if licensed), add the same group.
1. Leave the impersonation-protection exceptions empty for now (add trusted senders/domains only if a false positive appears in validation).
1. Save. The preset now governs anti-spam, anti-malware, anti-spoof and (if licensed) anti-phish, Safe Links, Safe Attachments for the pilot — with Microsoft-maintained settings.

*If the Standard preset fully meets the design, **skip 3d–3f** (custom policies) and go to 3g. Build custom policies **only** for a specific gap the preset cannot express.*

3d. Custom anti-spam / anti-malware (EOP) — only if a preset gap requires it

Create named custom policies **above** the default in priority, scoped to `Hygiene-Pilot`:

- Anti-spam (hosted content filter): `New-HostedContentFilterPolicy -Name "Anti-Spam – Inbound – Pilot" ...`

then `New-HostedContentFilterRule -Name "Anti-Spam – Inbound – Pilot" -HostedContentFilterPolicy "Anti-Spam – Inbound – Pilot" -SentToMemberOf "Hygiene-Pilot"`. Set verdict actions (e.g. high-confidence phishing → **Quarantine**), the **bulk threshold** (BCL, default 7 — tune up/down only from data), and the **quarantine policy** per action.

- Anti-malware: `New-MalwareFilterPolicy -Name "Anti-Malware – Inbound – Pilot" -EnableFileFilter $true ...`

with the common-attachments filter enabled, then `New-MalwareFilterRule ... -SentToMemberOf "Hygiene-Pilot"`.

- **Use** `-WhatIf` **first** (the provided config-helper script does exactly this).

3e. Anti-phishing (Defender for Office 365) — `Anti-Phish – Standard – Pilot`

Requires Defender for Office 365 (Plan 1 or 2). Skip if EOP-only.

Only if not covered by the preset: create `Anti-Phish – Standard – Pilot` (`New-AntiPhishPolicy` + `New-AntiPhishRule ... -SentToMemberOf "Hygiene-Pilot"`). Enable impersonation protection for a small list of high-value users/domains, mailbox intelligence, and set the action for detected impersonation to **Quarantine** with the chosen quarantine policy. Keep the protected-user list small to avoid false positives.

3f. Safe Attachments & Safe Links (Defender for Office 365)

Requires Defender for Office 365 (Plan 1 or 2). Skip if EOP-only.

Only if not covered by the preset:

- **Safe Attachments** `Safe-Attach – Standard – Pilot`: `New-SafeAttachmentPolicy` (Action =

Dynamic Delivery recommended) + `New-SafeAttachmentRule ... -SentToMemberOf "Hygiene-Pilot"`. Also enable the **global** setting to protect SharePoint/OneDrive/Teams (`Set-AtpPolicyForO365 -EnableATPForSPOTeamsODB $true`) and Safe Documents if E5 (`-EnableSafeDocs $true`).

- **Safe Links** `Safe-Links – Standard – Pilot`: `New-SafeLinksPolicy` (enable URL rewrite, scan on

click, do not let users click through to the original URL) + `New-SafeLinksRule ... -SentToMemberOf "Hygiene-Pilot"`.

3g. Quarantine policy & notifications — `Quarantine – Notify – Prod`

- Confirm/assign the quarantine policy each verdict uses (from Design). For end-user-visible

quarantine use `DefaultFullAccessWithNotificationPolicy`; for phishing/malware use `AdminOnlyAccessPolicy`.

- Enable **quarantine notifications** so recipients learn of held mail and can request release

(governed by Requirement #5's decision).

- If a custom quarantine policy is needed: `New-QuarantinePolicy -Name "Quarantine – Notify – Prod" ...`.

3h. Tenant Allow/Block List (TABL)

• Add deliberate allows/blocks in the Defender portal > **Threat policies > Tenant Allow/Block Lists**, or PowerShell `New-TenantAllowBlockListItems -ListType Sender -Allow -Entries "good@partner.com"` / `-Block` for known-bad senders, domains, URLs (`-ListType Url`), or file hashes (`-ListType FileHash`). Set expirations on allows (`-NoExpiration` only when justified).

• **This is the only sanctioned exception mechanism** — it replaces the transport-rule allow-lists retired in 3a.

Stage 4 — Pilot

Goal: run real mail through the pilot config and watch for false positives/negatives.

1. Leave the pilot config running for an agreed window (e.g. 5–10 business days).
2. Have pilot users report any misfiled mail; monitor quarantine daily (the reporting script produces the quarantine/allow-block review report).
1. Tune from **data only**: adjust the bulk (BCL) threshold, add a specific TABL allow, or add an impersonation exception — never widen a filter globally.

Gate 4: Over the pilot window, threats are caught (Testing section) **and** the false-positive rate is acceptably low (target: no legitimate business mail lost; any FP resolvable via a specific TABL allow, not a filter downgrade). **Fail** → tune and re-pilot; do not expand.

Stage 5 — Validate

Run the full **Testing** procedures (next section) against the pilot: spam (GTUBE), malware (EICAR), spoof, bulk, and — if Defender for Office 365 — Safe Links and Safe Attachments. Every test must hit its expected pass result. Confirm quarantine notifications deliver and release works.

Gate 5: All Testing pass/fail checks pass. **Fail** → troubleshoot (Troubleshooting section), fix, re-validate.

Stage 6 — Expand

Goal: roll the validated baseline to the rest of the organization.

1. **Preset path:** in the Standard preset, change the scope from `Hygiene-Pilot` to the full organization (or the appropriate groups/domains). Escalate exec/finance groups to the **Strict** preset if that was the design.
1. **Custom path:** widen each named policy's rule (`Set-*FilterRule`/`Set-AntiPhishRule` etc.) from `-SentToMemberOf "Hygiene-Pilot"` to the production scope.
1. Keep the quarantine review cadence and the reporting script on a schedule.
2. Retire the disabled legacy transport rules (from 3a) once you are confident, having kept the export for rollback.

Gate 6: Post-expand, monitor the first days closely; the reporting script's false-positive / spoof-intelligence analysis should show no spike in legitimate mail being quarantined.

Rollback (any stage)

- **Preset:** remove the pilot/production scope from the Standard/Strict preset — protection reverts to the prior state.
- **Custom policy:** `Disable-*Rule` or delete the named policy; higher-priority default resumes.
- **Transport rules:** re-enable / re-import the archived rule from the Stage 1 baseline.
- **TABL:** remove the specific allow/block entry.

Because every change is scoped and named, rollback is targeted and does not disturb unrelated mail flow.

Testing & Validation

Run these against the **pilot scope** before expanding (Stage 5). Each test states the procedure and the **expected pass/fail** result. Use only safe test artifacts (GTUBE, EICAR) — **never real malware**. Send from a controlled external address into a test mailbox inside `Hygiene-Pilot`.

> *The provided* `Test-MailHygienePolicy.ps1` *validation script automates the read-side checks (policy presence/scope, quarantine action, TABL entries, authentication posture) and summarizes pass/fail. Message-injection tests below are performed by actually sending mail.*

T1 — Anti-spam verdict (GTUBE)

- **Procedure:** Send a message from the external test sender to a pilot mailbox with the standard **GTUBE** spam-test string as the body.
- **Expected pass:** The message is treated as **high-confidence spam** — quarantined (or moved to Junk, per your anti-spam action). It appears in quarantine and/or the message trace shows the spam verdict.
- **Fail:** Message lands in the Inbox untouched → check the anti-spam policy scope, priority, and any lingering `SCL -1` transport rule (Troubleshooting T-A).

T2 — Anti-malware (EICAR)

- **Procedure:** Send a message with the **EICAR** anti-malware test file attached (a benign industry-standard test file — not malware) to a pilot mailbox.
- **Expected pass:** The attachment/message is caught by anti-malware and **quarantined**; message trace shows the malware verdict. Recipient does not receive the file.
- **Fail:** File delivered → verify the anti-malware policy (or Standard preset) is scoped to the pilot and the common-attachments filter is enabled.

T3 — Spoof / anti-phishing (unauthenticated spoof of your domain)

• **Procedure:** From the controlled external sender, send a message with a **From** address that spoofs one of your own accepted domains (unauthenticated), to a pilot mailbox.

• **Expected pass:** Spoof intelligence / anti-phishing marks it as spoof — quarantined or Junk with the composite-authentication (`compauth`) failure visible in headers. With DMARC `p=reject/quarantine` the honoring behavior applies.

• **Fail:** Delivered as legitimate → confirm SPF/DKIM/DMARC (Requirement #2), spoof intelligence is on, and no TABL allow or transport rule is whitelisting the sender.

T4 — Bulk mail threshold (BCL)

• **Procedure:** Send/receive from a known bulk sender (e.g. a marketing newsletter you control) and observe the **bulk complaint level (BCL)** verdict.

• **Expected pass:** Legitimate bulk you want is **delivered**; unwanted bulk above the threshold is filtered. The BCL in headers matches your configured threshold behavior.

• **Fail:** Wanted bulk quarantined → tune the BCL threshold **up** from data, or add a specific TABL allow — do not disable bulk filtering.

T5 — Safe Attachments (Defender for Office 365 only)

Skip if EOP-only. *Requires Defender for Office 365.*

• **Procedure:** Send a message with a benign attachment to a pilot mailbox and observe detonation behavior; use Microsoft's documented Safe Attachments test guidance / a known test file.

• **Expected pass:** Safe Attachments processes the attachment (Dynamic Delivery: body arrives, then the attachment after scan). Detonation events are visible in the Defender portal.

• **Fail:** No Safe Attachments processing → confirm the license, the `Safe-Attach – Standard – Pilot` policy/preset scope, and the global ATP setting.

T6 — Safe Links (Defender for Office 365 only)

Skip if EOP-only. *Requires Defender for Office 365.*

• **Procedure:** Send a message containing a URL to a pilot mailbox; inspect the received message.

• **Expected pass:** The URL is **rewritten/wrapped** (Safe Links) and is checked at time of click; a known-malicious test URL is blocked at click.

• **Fail:** URL not rewritten → confirm the license and the `Safe-Links – Standard – Pilot` policy/preset scope and that URL rewrite is enabled.

T7 — Quarantine notification & release

• **Procedure:** For a message quarantined in T1/T3, confirm the recipient receives a **quarantine notification **and can** request release** (per `Quarantine – Notify – Prod`). As admin, release a message.

• **Expected pass:** Notification delivered; recipient can request release; admin release delivers the message to the Inbox.

• **Fail:** No notification → verify quarantine notifications are enabled on the quarantine policy and the policy is assigned to the verdict's action.

T8 — Tenant Allow/Block List behaves

• **Procedure:** Add a test **allow** for a specific sender and a test **block** for another in the TABL; send from each into a pilot mailbox.

• **Expected pass:** The allowed sender is delivered even if otherwise borderline; the blocked sender is blocked/quarantined. Remove the test entries after.

• **Fail:** Entry not honored → check the TABL entry type/scope and expiration.

T9 — No legitimate mail lost (false-positive gate)

• **Procedure:** Over the pilot window, review the quarantine and the reporting script's false-positive analysis for any **legitimate business mail** that was quarantined.

• **Expected pass:** No legitimate business mail lost; any borderline case resolved by a specific TABL allow or a data-driven threshold tune — **not** by downgrading a filter.

• **Fail:** Legitimate mail quarantined and unresolved → treat as a Gate 4/5 failure; tune and re-validate before expanding.

Overall validation gate: T1–T4 and T7–T9 pass on every tenant; T5–T6 additionally pass where Defender for Office 365 is licensed. Only then proceed to **Expand**.

Troubleshooting

Common failure modes when configuring and tuning Microsoft 365 mail hygiene, with resolutions. Use the provided scripts to diagnose: `Get-MailHygieneScopeHealth.ps1` (which policy applies), `Test-MailHygienePolicy.ps1` (validation), and `Get-QuarantineAndAllowBlockReport.ps1` (quarantine / allow-block review).

T-A. Spam/malware/phish delivered to the Inbox despite the policy

• **Likely cause:** A **filter-bypassing mail-flow rule** (transport rule setting `SCL -1`), a broad

allow-list rule, or a **Tenant Allow/Block List** allow entry is whitelisting the sender — or the policy is not scoped to the recipient.

- **Resolve:** Run `Get-MailHygieneAssessment.ps1` and look for the `SCL -1` RISK flags; disable

those rules (retire them into TABL). Run `Get-MailHygieneScopeHealth.ps1 -User <recipient>` to confirm which policy actually applies. Check the TABL for an over-broad allow. Confirm the recipient is in the policy scope (pilot group or expanded scope).

T-B. Legitimate mail is being quarantined (false positive)

- **Likely cause:** Bulk (BCL) threshold too aggressive, an impersonation-protection list too broad,

spoof intelligence flagging a legitimate on-behalf sender, or the Strict preset applied to users who need Standard.

- **Resolve:** Identify the verdict from the message trace / `Get-QuarantineAndAllowBlockReport.ps1`.

Fix with the **least broad** action: add a **specific TABL allow** for the sender/domain, raise the **BCL threshold** from data, add a targeted impersonation exception, or move the user from Strict to Standard. **Never** disable the filter or add an `SCL -1` rule.

T-C. "Safe Links / Safe Attachments / impersonation protection is missing"

- **Likely cause:** The tenant is **EOP-only** (or the specific users are not licensed for Defender

for Office 365). These are **Defender for Office 365** features — they do not exist on EOP.

- **Resolve:** Verify licensing (Requirement #1): Microsoft 365 admin center > Billing > Licenses.

Confirm the Safe Links / Safe Attachments policy pages exist in the Defender portal. If EOP-only, either license Defender for Office 365 for those users or proceed with EOP-only hygiene. On **Government clouds**, also confirm the feature has rolled out for that cloud — **verify in your tenant**.

T-D. Cannot reach the portal / cmdlet errors on a Government tenant

- **Likely cause:** Wrong portal URL or `Connect-ExchangeOnline` environment for GCC/GCC High/DoD.
- **Resolve:** Use `security.microsoft.us` (GCC High/DoD) and

`admin.exchange.microsoft.us`; connect with `Connect-ExchangeOnline -ExchangeEnvironmentName O365USGovGCCHigh` (or `O365USGovDoD`). For GCC, confirm the correct URL for your tenant. **Do not assume Commercial URLs.**

T-E. Quarantine notifications not delivered / users can't request release

- **Likely cause:** The quarantine policy assigned to the verdict lacks end-user permissions/

notifications, or an admin-only policy is applied where user access was intended.

- **Resolve:** Confirm the verdict's action uses `DefaultFullAccessWithNotificationPolicy` (or your

`Quarantine – Notify – Prod` policy) and that quarantine notifications are enabled. High-confidence phishing/malware intentionally use `AdminOnlyAccessPolicy` (no self-release) — that is by design.

T-F. A user gets a different verdict than expected

- **Likely cause: Policy precedence** — only the highest-priority matching policy of each type

applies. A higher-priority custom policy or a preset is overriding what you expected.

- **Resolve:** Run `Get-MailHygieneScopeHealth.ps1 -User <user>` to see the effective policy per

type and the priority order. Adjust priorities or scope so the intended policy wins.

T-G. EOP not filtering correctly when a third-party gateway is in front

- **Likely cause:** EOP is evaluating the **gateway's IP** as the source rather than the true

external sender, so connection filtering and spoof intelligence misbehave.

- **Resolve:** Configure **Enhanced Filtering for Connectors (skip listing)** on the inbound

connector so EOP sees the real source IP (`Get-MailHygieneScopeHealth.ps1` reports current state). Do not add the gateway IPs to the connection-filter allow list. Defer the third-party console to the vendor's docs.

T-H. Spoof of your own domain still delivered

- **Likely cause:** Weak or missing **SPF/DKIM/DMARC**, so composite authentication cannot fail the

spoof; or a TABL allow / transport rule is permitting it.

- **Resolve:** Confirm DKIM is enabled per domain (`Get-DkimSigningConfig`), SPF/DMARC published

(`Test-MailHygienePolicy.ps1` checks these), spoof intelligence is on, and no allow entry is whitelisting the spoofer. Tighten DMARC toward `p=quarantine`/`p=reject` as data supports.

T-I. `Connect-ExchangeOnline` or a cmdlet fails

- **Likely cause:** EXO V3 module missing/outdated, Basic Auth (retired), or insufficient role.

- **Resolve:** `Install-Module ExchangeOnlineManagement` / `Update-Module`; use modern-auth /

MFA sign-in; ensure the admin has the least-privilege roles (Security Administrator + Exchange Administrator for hygiene). Never use stored credentials.

T-J. Changes seem to have no effect immediately

- **Likely cause:** Policy propagation delay; or the change was made in a **dry-run** (the config

helper defaults to `-WhatIf` unless `-Commit` is passed).

- **Resolve:** Confirm the change actually committed (re-run `Set-MailHygieneBaseline.ps1` with

`-Commit`, or verify with `Get-*Policy`/`Get-MailHygieneScopeHealth.ps1`). Allow time for propagation, then re-test with a fresh message.

Best Practices

Durable practices for keeping Microsoft 365 mail hygiene effective and low-false-positive over time.

Baseline & policy management

- **Prefer preset security policies.** The **Standard** preset is the recommended baseline for most

users; **Strict** for high-risk roles (execs, finance, IT admins). Presets are Microsoft-maintained and stay current — you inherit new protections automatically. Reach for custom policies only for a specific gap the preset cannot express.

- **Understand policy precedence.** For a given user, only the **highest-priority matching policy of

each type** applies. Presets have their own ordering (Strict > Standard > custom > default). Keep custom policies minimal and their priority deliberate.

- **Never disable filtering to fix a false positive.** Every exception belongs in the **Tenant

Allow/Block List**, scoped and time-bound. `SCL -1` transport rules and broad allow-list rules are the #1 cause of both missed threats and confusing behavior — retire them.

Licensing discipline

- **Know your plan and re-verify it.** EOP-only vs Defender for Office 365 Plan 1/2 determines what

you can configure. License changes (or bundle changes) alter available features. Confirm capability **in the tenant**, not from the SKU name — Defender for Office 365 feature availability also differs on **Government clouds (GCC / GCC High / DoD)**.

Authentication foundation

- **Keep SPF, DKIM, and DMARC healthy on every sending domain.** Hygiene reasons over authenticated

signals; weak authentication increases both false positives and missed spoofing. Move DMARC from `p=none` (monitor) toward `p=quarantine`/`p=reject` as data supports it.

- **Enable DKIM for all custom domains** (`Set-DkimSigningConfig -Enabled $true` after the CNAMEs

exist), not just the onmicrosoft domain.

Quarantine & allow/block governance

- **Review quarantine on a schedule** (the reporting script produces the review report). Unreviewed

quarantine means real false positives are lost and real threats go unstudied.

- **Use notifications** so end-users can self-serve release requests for false positives — reduces

help-desk load and mail loss.

• **Right-size release permissions:** admin-only release for high-confidence phishing/malware; request-release for spam/bulk.

• **Time-bound TABL allows.** Set expirations; a permanent allow is a standing risk. Review the allow list periodically and remove stale entries.

Tuning to minimize false positives

• **Tune from data, incrementally.** Adjust the **BCL** (bulk) threshold or add a specific TABL allow based on observed misfiling — never a broad downgrade.

• **Keep impersonation-protection lists tight.** Protect a small set of genuinely high-value users/domains; over-broad impersonation lists generate false positives.

• **Use spoof intelligence insight** and the spoof-intelligence analysis report to allow legitimate spoofers (e.g. bulk senders sending on your behalf) deliberately, rather than loosening spoof protection.

Third-party gateways

• If a third-party hygiene gateway sits in front of EOP, configure **Enhanced Filtering for Connectors (skip listing)** so EOP evaluates the true source IP, and avoid double-filtering conflicts. Defer the third-party console to the vendor's docs; integrate at the connector level.

Change control & operations

• **Every hygiene change is high-impact to production mail** — stage on a pilot, validate against the gates, keep a rollback. Name every artifact `<Purpose> – <Scope> – <Stage>` and reuse the name.

• **Run the assessment script periodically** to detect configuration drift (new bypass rules, policies out of baseline, expired-but-still-present allows).

• **Schedule the reporting script** so quarantine review and false-positive/spoof analysis are routine, not reactive.

• **Automate read-only; gate writes.** All provided scripts are read-only or `-WhatIf` by default; changes require an explicit switch — keep that discipline in any further automation. No stored credentials; always modern-auth `Connect-ExchangeOnline` / `Connect-MgGraph`.

Deliverables Summary

This solution delivers a complete, self-guided package to configure and tune Microsoft 365 mail hygiene (EOP + Defender for Office 365), plus five PowerShell tools. Everything is white-label and safe-by-default.

Documentation

- **Solution Overview** — the hygiene stack (EOP anti-spam/malware/spoof, Defender for Office 365 anti-phish/Safe Links/Safe Attachments), preset vs custom policies, quarantine, reference design, benefits, limitations, and the deployment model.
- **Requirements Guide** — solution-specific prerequisites (confirmed EOP/Defender for Office 365 licensing; SPF/DKIM/DMARC; pilot scope; test mailbox + safe test artifacts; quarantine owner; a captured before-state including filter-bypassing transport rules; Government-cloud confirmation), each with how to verify/implement, on top of the shared messaging requirements.
- **Implementation Guide** — exact ordered steps (portal paths **and** EXO PowerShell cmdlets) through Assess → Design → Configure → Pilot → Validate → Expand, every artifact named, with pass/fail gates and a rollback.
- **Testing & Validation** — nine procedures (GTUBE spam, EICAR malware, spoof, bulk/BCL, Safe Attachments, Safe Links, quarantine notify/release, TABL behavior, and a false-positive gate), each with expected pass/fail.
- **Troubleshooting** — common failure modes and resolutions.
- **Best Practices** — durable hygiene tuning, quarantine/allow-block governance, licensing discipline, and false-positive minimization.

PowerShell tools (5) — EXO V3 / Microsoft Graph, read-only or `-WhatIf` by default

1. `Get-MailHygieneAssessment.ps1` — *Discovery / assessment (read-only).* Exports the current hygiene posture — anti-spam, anti-malware, anti-phish, Safe Links/Attachments, connection filter, quarantine policies, preset state, Tenant Allow/Block List — and flags risky legacy mail-flow rules (e.g. `SCL -1` bypasses) and gaps against the Standard baseline. Produces the rollback baseline. Never changes anything.
1. `Set-MailHygieneBaseline.ps1` — *Configuration helper (safe-by-default, `-WhatIf`).* Helps apply/tune the baseline: scope the Standard preset to a pilot group, or create the named custom anti-spam/anti-malware/anti-phish policies and the quarantine policy. **Dry-run by default** — it only makes changes when `-Commit` is passed; otherwise it reports the intended actions via `-WhatIf`. No stored credentials.
1. `Test-MailHygienePolicy.ps1` — *Validation (read-only).* Verifies that the expected policies exist and are scoped correctly, the quarantine actions are set, TABL entries are present, and SPF/DKIM/DMARC authentication posture is healthy — summarizing pass/fail for the validation gates.
1. `Get-QuarantineAndAllowBlockReport.ps1` — *Reporting (read-only).* Produces the quarantine review report and the Tenant Allow/Block List review (including stale/expiring allows) for the review owner, plus a false-positive / spoof-intelligence oriented summary from message data.
1. `Get-MailHygieneScopeHealth.ps1` — *Scope / health helper (read-only).* Resolves which policy

actually applies to a given user (policy precedence), lists preset scope and custom policy priorities, and reports connection-filter and Enhanced-Filtering-for-Connectors state — the helper used to answer "why did this user get this verdict?".

> *All scripts require the **ExchangeOnlineManagement (EXO V3)** module (and **Microsoft Graph PowerShell** where noted); connect with modern-auth* `Connect-ExchangeOnline` */* `Connect-MgGraph`*. **No hardcoded credentials or secrets.** Writes are gated behind an explicit switch.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

Get-MailHygieneAssessment.ps1

Get-MailHygieneScopeHealth.ps1

Get-QuarantineAndAllowBlockReport.ps1

Set-MailHygieneBaseline.ps1

Test-MailHygienePolicy.ps1